MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D12

Risk Treatment and Retesting Record

Deliverable 12 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Risk Treatment and Retesting Record

MDM-D12

1. Purpose and Scope

This document records the Risk Owner decisions on the items raised in MDM-D11. It updates the current residual risk for each risk in MDM-D04 and sets how and when each recommendation is retested.

It covers the four decisions in MDM-D11 Section 6 (D-01 to D-04), the eight risks MDM-RSK-001 to MDM-RSK-008, and the twelve recommendations MDM-REC-001 to MDM-REC-012.

Residual risk is assessed and justified here. In MDM-D04, only the Current Residual Risk and Target Residual Risk fields are updated, with the value and a reference to this document. The MDM-D04 method and other fields do not change.

Risk Owners decide treatment and accept residual risk. GRC records the decisions and the facts behind them, and plans the retests. Closure of MDM-FND-003 is verified by Internal Audit, not the CISO.

MDM-CTL-006, MDM-CTL-008 and the MDM-D07 requirements outside the MDM-D10 sample are not covered. They belong to the next testing cycle.

No tenant was configured. All decisions, dates, residual ratings and retest results are simulated.

2. Method

2.1 Residual Risk Rules

Current residual risk uses the MDM-D04 scales and score bands. Each finding in MDM-D11 is already rated on the risk it leaves open, so its score is used as the residual measure.

Rule	Description
RR1 – Credit	Only tested evidence reduces risk. A path counts as treated when a key step that covers it passed in MDM-D10, even if the test as a whole is Not Effective. Paths that failed or were not tested get no credit. Planned controls do not reduce risk, as in MDM-D04.
RR2 – Score	Current residual is the highest score among open findings linked to or rated against the risk. It cannot exceed the inherent score.
RR3 – Untested	A risk whose controls were not tested stays Not assessed. A finding rated against it does not make it assessed.
RR4 – Acceptance	Accepting a risk does not lower its score. It changes the treatment status only.
RR5 – Provisional	A residual that relies on an untested item from MDM-D11

Rule	Description
	Section 4.3 is marked provisional until the related recommendation is retested.
RR6 – Target	Target residual is the expected score once the open recommendations close. The Risk Owner approves it, and it holds only after a passed retest.

RR2 assumes the other tested controls work and that separate findings do not add up. Where findings on the same risk would raise the likelihood of one scenario together, the residual is raised and the reason is written in Section 4, as in MDM-D11 rule R6.

2.2 Treatment Options

Option	Meaning
Mitigate	Apply or fix controls through the MDM-D11 recommendations.
Accept	Keep the risk at its current level, with a recorded rationale and a review trigger.
Avoid	Stop the activity that creates the risk, such as removing a device model from the approved list.
Transfer	Share the risk with a third party. Not used in this case study.

Each decision records the option, the Risk Owner, the date, any condition and what would reopen it. Decisions are shown with the inherent risk level, not the residual.

2.3 Retest Rules

Rule	Description
Trigger	The Control Owner reports the recommendation complete.
Timing	Retest is done before the finding's due date. Due dates run from the date the Control Owner agreed the finding (MDM-D11 Section 2.4).
Tester	The GRC Analyst retests. The Control Owner does not retest their own control. MDM-FND-003 is retested by Internal Audit.
Evidence	Evidence meets the MDM-D09 standards and is indexed there.
Pass	The success indicator in the recommendation is met. The finding closes and the residual is updated in Section 4.
Fail	The finding stays open and is re-rated with the MDM-D11 rules. The due date does not change. An overdue finding is reported to the Risk Owner.

3. Risk Owner Decisions

The Business Owner decided the four items in MDM-D11 Section 6 on 16 November 2026. Two are accepted, one with a condition still open. One awaits an assessment and one is not yet needed. Risk levels are inherent, as in Section 2.2.

Item	Risk	Decision	Treatment	Condition	Reopens When
D-01: Access window after loss of compliance (L-02)	MDM-RSK-003, Medium (9)	Option 2. IT Operations assesses ways to shorten the window before the Business Owner decides.	Mitigate, decision pending	Until the decision, the window stays within the 28-hour bound in MDM-D08 Section 4.2.	The IT Operations assessment is received. The Business Owner then accepts the window or approves a change.
D-02: iOS Share extension exposure (MDM-FND-001, MDM-REC-001)	MDM-RSK-002, High (12)	Option 1. The exposure is accepted, with encryption as the protection that applies.	Accept	Shared files cannot be opened outside managed apps, confirmed by the MDM-REC-001 retest.	A copy is shown to be readable outside managed apps, or the MDM-REC-001 retest fails (Section 6).
D-03: Android immediate lock (MDM-FND-005, MDM-REC-005)	MDM-RSK-001, Medium (9)	Not decided. No decision is needed until MDM-REC-005 measures the window.	Mitigate through MDM-REC-005	None	MDM-REC-005 finds a model that cannot enforce immediate lock. The Business Owner then accepts that model's measured window or removes the model.
D-04: BYOD without MDM enrollment, against SAMA CSF	MDM-RSK-002, High (12)	Option 1, conditional. The deviation is accepted, with app-level controls as the	Accept, not yet effective	Takes effect when MDM-REC-011 confirms encryption in transit. The	The MDM-REC-011 review fails. The decision then returns to the Business Owner.

Item	Risk	Decision	Treatment	Condition	Reopens When
3.3.10 consideration 4(e)		alternative. The CISO advised in favour.		rationale is added to the MDM-D05 crosswalk in its next revision, with MDM-REC-009.	

MDM-RSK-002 carries two accepted items and one finding under remediation (MDM-FND-002). Its treatment is mixed: Accept for D-02 and D-04, Mitigate for MDM-REC-002.

4. Residual Risk Update

Five of the eight risks were assessed, and all five now sit at Medium. The two High risks, MDM-RSK-002 and MDM-RSK-005, fall to Medium (9) and Medium (6). The three risks scored 6 stay Not assessed because their controls were not tested.

Risk	Inherent	Tests	Open Findings	Current Residual	Target Residual	Treatment
MDM-RSK-002	**High (12)**	MDM-TST-001, 002	MDM-FND-001 (8), MDM-FND-002 (9)	**Medium (9), provisional**	**Medium (8)**	Mitigate and Accept (D-02, D-04)
MDM-RSK-005	**High (12)**	MDM-TST-003, 004	MDM-FND-003 (6)	**Medium (6)**	**Low (3)**	Mitigate
MDM-RSK-001	**Medium (9)**	MDM-TST-006, 008	MDM-FND-005, 007, 009 (6 each)	**Medium (6)**	**Low (3)**	Mitigate (D-03 pending)
MDM-RSK-003	**Medium (9)**	MDM-TST-005	MDM-FND-004 (6)	**Medium (6)**	**Medium (6) until D-01 is decided**	Mitigate (D-01 pending)
MDM-RSK-007	**Medium (9)**	MDM-TST-007	MDM-FND-006 (6)	**Medium (6)**	**Low (3)**	Mitigate
MDM-RSK-004	**Medium (6)**	None	None	**Not assessed**	**Not set**	Test MDM-CTL-004 (MDM-REC-010)

Risk	Inherent	Tests	Open Findings	Current Residual	Target Residual	Treatment
MDM-RSK-006	Medium (6)	None for MDM-CTL-006	MDM-FND-008 (4), rated against it	Not assessed	Not set	Next test cycle
MDM-RSK-008	Medium (6)	None	None	Not assessed	Not set	Next test cycle

Notes on the ratings

- MDM-CTL-002 is rated Not Implemented in MDM-D13 because both of its tests were Not Effective. The fall of MDM-RSK-002 from High (12) to Medium (9) is credited to the transfer paths that passed (MDM-TST-001, key steps 5, 6, 8 and 10–13), not to the control as a whole (RR1). The two paths that failed are scored as MDM-FND-001 and MDM-FND-002.
- MDM-RSK-002 takes the higher of its two findings (RR2). The two findings affect different devices through different paths, so together they do not raise the likelihood of one scenario. The rating is provisional until MDM-REC-011 confirms encryption in transit (RR5). App-level protections in MDM-D07 Sections 4.6–4.13 and 4.16 were not tested, so the rating covers the tested paths only.
- MDM-RSK-002 cannot go below Medium (8) while D-02 stands. The accepted Share extension exposure keeps the MDM-FND-001 score after MDM-REC-002 closes.
- MDM-RSK-005 covers the tested scope only. Permission and scope behavior in MDM-D07 Section 5.2 was not tested and is a priority for the next cycle.
- MDM-RSK-001 relies on the MDM-REC-005 measurement. If D-03 accepts a measured window for a model, the target is reset with that window.
- MDM-RSK-003 keeps a Medium target while the D-01 window is undecided. Once D-01 is decided, the target is reset.
- The Low targets keep inherent Impact and set Likelihood to 1 – Rare, on the basis that every tested control works and every finding is closed. Each Risk Owner approved the targets on 16 November 2026. They hold only after a passed retest (RR6).

MDM-D04 Current Residual Risk and Target Residual Risk fields were updated with these values and a reference to this section. Earlier values (Not assessed) are kept here for traceability.

5. Retesting Plan

All twelve recommendations are planned for retest. Eleven are due by 14 February 2027 and one by 15 May 2027. The Control Owners agreed the findings on 16 November 2026, and the due dates follow MDM-D11 Section 2.4. No retest has been performed yet.

Rec	Item	Retest Method	Tester	Retest By
MDM-REC-001	MDM-FND-001	Repeat MDM-TST-001 step 14 and confirm the shared file	GRC Analyst	14 February

Rec	Item	Retest Method	Tester	Retest By
		cannot be opened outside managed apps. Confirm the constraint is recorded in MDM-D07 Section 4.4.		2027
MDM-REC-002	MDM-FND-002	Repeat MDM-TST-002 steps 11–12 with a noncompliant corporate iPhone in OneDrive and the other five approved apps. Inspect MDM-EVD-007.	GRC Analyst	14 February 2027
MDM-REC-003	MDM-FND-003	Inspect the quarterly review record for a CISO decision on the IT Operations Manager's access.	Internal Audit	14 February 2027 for the first review; closure after the second
MDM-REC-004	MDM-FND-004	Inspect MDM-EVD-014 for three consecutive monthly reviews, the recurring task and the named backup reviewer.	GRC Analyst	14 February 2027
MDM-REC-005	MDM-FND-005	Inspect MDM-EVD-002 for a configuration per approved Android model. Repeat MDM-TST-006 step 8 on each model and measure the unlock window.	GRC Analyst	14 February 2027
MDM-REC-006	MDM-FND-006	Inspect every contractor departure in the period for sign-in failure evidence, and any incomplete action for escalation under MDM-D07 Section 5.8.	GRC Analyst	14 February 2027
MDM-REC-007	MDM-FND-007	Inspect the lost-device record for wipe confirmation or active tracking. Inspect every new loss record for confirmation, owner	GRC Analyst	14 February 2027

Rec	Item	Retest Method	Tester	Retest By
		and follow-up date.		
MDM-REC-008	MDM-FND-008	Inspect the approved retention period and its repository setting. Check that no activation record past the period remains.	GRC Analyst	15 May 2027
MDM-REC-009	MDM-FND-009	Inspect the revised MDM-D05 for the four controls, each with an ID, owner and linked risk, the NCA ECC 2-6-3-3 mapping and the D-04 rationale.	Internal Audit	14 February 2027
MDM-REC-010	MDM-CTL-004	Confirm MDM-EVD-023 is Accepted in MDM-D09, then test MDM-CTL-004 with a new procedure in MDM-D10.	GRC Analyst	14 February 2027
MDM-REC-011	Encryption in transit	Confirm MDM-EVD-057 is Accepted and the network path review is recorded.	GRC Analyst	14 February 2027
MDM-REC-012	A-06, enterprise user MFA	Confirm the IAM owner's written confirmation is filed in MDM-EVD-069. Raise a finding if coverage is incomplete.	GRC Analyst	14 February 2027

Notes on the plan

- Internal Audit retests MDM-REC-009 because the GRC Analyst prepares the MDM-D05 draft. GRC does not verify its own work.
- MDM-REC-003, 004 and 006 have success indicators that run over time. The retest checks what exists by the due date. MDM-REC-003 closes only after the second quarterly review is recorded.
- The MDM-REC-005 result decides D-03 and may trigger a re-rating of MDM-FND-005 (Section 6).
- The MDM-REC-011 result decides whether D-04 takes effect and whether the MDM-RSK-002 rating stays provisional.
- MDM-REC-010 brings MDM-RSK-004 into assessment. Its residual is rated in Section 4 once the test is done.

6. Re-rating Triggers

Six events reopen a rating or a decision. When one occurs, the finding is re-rated with the MDM-D11 rules, Section 4 is updated, and the Risk Owner is informed. A new due date applies

only when the severity rises. It runs from the date the Control Owner agrees the re-rated finding, and it can only be earlier than the current one.

Trigger	Affects	Action
A shared copy can be read outside managed apps (MDM-REC-001 retest or other evidence).	MDM-FND-001, D-02, MDM-RSK-002	Impact rises to 3. MDM-FND-001 becomes 3 × 4 = 12, High, at the MDM-RSK-002 ceiling. D-02 returns to the Business Owner. MDM-RSK-002 current residual becomes High (12).
The Android unlock window exceeds one minute on any approved model (MDM-REC-005).	MDM-FND-005, D-03, MDM-RSK-001	MDM-FND-005 Likelihood is re-rated. D-03 goes to the Business Owner for that model.
Encryption in transit is not confirmed, or the network path review finds an issue (MDM-REC-011).	D-04, MDM-RSK-002	D-04 does not take effect and returns to the Business Owner. A finding is raised and rated against MDM-RSK-002.
Enterprise user MFA coverage is incomplete (MDM-REC-012).	Assumption A-06	A finding is raised and rated with the MDM-D11 rules.
The Business Owner decides D-01.	MDM-RSK-003	The target residual is reset from the decision.
A retest fails (Section 2.3).	The related finding and risk	The finding stays open and is re-rated. The due date does not change.

Assessing an untested risk is not a re-rating. MDM-RSK-004, 006 and 008 are rated in Section 4 when their controls are first tested.

7. Assumptions and Limitations

7.1 Assumptions

ID	Assumption
AS-01	A finding score in MDM-D11 is a fair measure of the risk it leaves open, so it can stand as the residual score (RR2).
AS-02	Controls tested effective in MDM-D10 keep operating until the retest.
AS-03	Separate findings on one risk affect different paths and do not add up, unless Section 4 says otherwise.
AS-04	Risk Owners act on the decisions in Section 3 and the triggers in Section 6

ID	Assumption
	when they occur.

7.2 Limitations

ID	Limitation
LM-01	No tenant was configured. All decisions, dates, residual ratings and retest plans are simulated.
LM-02	Residual ratings cover the tested scope only. App-level protections in MDM-D07 Sections 4.6–4.13 and 4.16, and permission behavior in Section 5.2, were not tested.
LM-03	MDM-RSK-004, 006 and 008 are not assessed. The overall residual picture is incomplete until they are tested.
LM-04	Target residuals are expectations, not results. They hold only after a passed retest.
LM-05	The MDM-RSK-002 rating is provisional until MDM-REC-011 is retested.
LM-06	No retest has been performed. This record will be updated with results by 15 May 2027.